



Bundesamt
für Sicherheit in der
Informationstechnik

Deutschland
Digital•Sicher•BSI

Technische Richtlinie BSI TR-03190

IT-Sicherheitsanforderungen für die Anbindung an das NOOTS

Version 0.7

KOMMENTIERUNGSFASSUNG



Änderungshistorie

<i>Version</i>	<i>Datum</i>	<i>Name</i>	<i>Beschreibung</i>
0.1	30.09.2025	BSI, Referat D25	Initiales Dokument zur Vorstellung auf ISB-Jahrestagung
0.4	04.11.2025	BSI, Referat D25	Arbeitsfassung zur internen Abstimmung
0.7	12.11.2025	BSI, Referat D25	Kommentierungsfassung

Tabelle 1: Versionshistorie

Bundesamt für Sicherheit in der Informationstechnik
Postfach 20 03 63
53133 Bonn
Tel.: +49 22899 9582-0
E-Mail: registermodernisierung@bsi.bund.de
Internet: <https://www.bsi.bund.de>
© Bundesamt für Sicherheit in der Informationstechnik 2025

Danksagung

Das Bundesamt für Sicherheit in der Informationstechnik bedankt sich beim Bundesverwaltungsamt und dessen Dienstleistern für die gute Zusammenarbeit, den regelmäßigen Austausch und die hilfreiche Unterstützung durch Hinweise und Kommentare bei der Erstellung dieser Technischen Richtlinie.

Inhalt

1	Einleitung.....	6
1.1	Thematische Einordnung.....	6
1.2	Zielgruppe	7
1.3	Aufbau der Technischen Richtlinie	7
1.4	Schlüsselwörter	8
2	Begriffsdefinitionen.....	9
3	Der Nachweisabrufprozess unter Verwendung des NOOTS	12
4	Definition Anschlussklassen	14
5	Vorgaben zur Umsetzung von IT-Grundschutz und allgemeine Anforderungen an den Betrieb	16
5.1	Anforderungen zur Umsetzung von IT-Grundschutz.....	16
6	Vorgaben bezüglich SAK.....	19
6.1	Vorgaben zu Installation und Inbetriebnahme des SAK	19
6.2	Vorgaben an den Betrieb eines SAK	20
6.2.1	Allgemeine Vorgaben an den Betrieb eines SAK.....	20
6.2.2	Protokollierung und Fehlerbehandlung	20
6.2.3	Vorgaben zum Betrieb eines SAK mit mehreren Mandanten	21
6.3	Vorgaben zur Verfügbarkeit	22
7	Anforderungen an Data Consumer (DC) und Data Provider (DP).....	23
7.1	Anforderungen, die für DC und DP gelten.....	23
7.2	Spezifische Anforderungen an Data Provider (DP).....	24
7.3	Anforderungen an Data Consumer	26
	Literaturverzeichnis	27
	Abkürzungsverzeichnis.....	29

1 Einleitung

1.1 Thematische Einordnung

In einer zunehmend digitalisierten Welt muss der deutsche Staat seinen Bürgerinnen und Bürgern und der Wirtschaft zeitgemäße Verwaltungsstrukturen bieten. Eines der größten Vorhaben zur Digitalisierung der öffentlichen Verwaltung ist die Registermodernisierung: Die staatlichen Register, in denen sich Daten und Nachweise der Bürgerinnen, Bürger und Unternehmen befinden, sollen zum einen durch die Verwendung der steuerlichen Identifikationsnummer (IDNr.) bzw. der bundeseinheitlichen Wirtschaftsnummer (beWiNr.), als neue, eindeutige Ordnungsmerkmale zukunftstauglich gemacht werden. Zum anderen sollen die Register durch das Nationale Once-Only Technical System (NOOTS) miteinander, mit Onlinediensten und mit Fachverfahren der Verwaltung vernetzt werden.

Diese Vernetzung dient der Umsetzung des durch die Single Digital Gateway Verordnung (1) formulierten Once-Only-Prinzips: Daten, die der öffentlichen Verwaltung an einer Stelle bereits vorliegen, sollen nicht erneut erhoben werden müssen, wenn sie an anderer Stelle benötigt werden. Stattdessen sollen Bürgerinnen, Bürger und Unternehmen mit Hilfe von Onlineportalen in die Lage versetzt werden, ihre Nachweise aus Registern an andere staatliche Stellen übermitteln zu lassen, wenn dies beispielsweise als Anlage zu Onlineanträgen nötig ist. Das eigenständige Hochladen dieser Dokumente oder gar der Behördengang zum Vorzeigen des Dokumentes können damit entfallen. Gleichzeitig wird für die öffentliche Verwaltung der Mehrwert geschaffen, dass das Vertrauensniveau für die Authentizität und Aktualität der abgerufenen Daten hoch ist, da diese direkt aus einem staatlichen Register stammen. Dies stellt einen Beitrag zur Ende-zu-Ende Digitalisierung dar. Diese medienbruchfreie Kommunikation beschleunigt das Verwaltungshandeln, was auch der Wirtschaft zu Gute kommt, die statistisch gesehen die meisten Verwaltungskontakte aufweist. Darüber hinaus werden durch die Vernetzung der Register und Fachverfahren perspektivisch auch antraglose Verfahren ermöglicht.

Die zentrale Transportinfrastruktur NOOTS, die diesen Datenaustausch ermöglicht, wird vom Bundesverwaltungsamt (BVA) als betriebsverantwortliche Stelle des NOOTS entwickelt und betrieben. Dies umfasst die zentralen Komponenten, die zur Abwicklung und Absicherung des Datenaustausches nötig sind, sowie die Bereitstellung der Sicheren Anschlussknoten (SAK), die den angebundenen Stellen zur Verfügung gestellt werden. Die SAK sind als Softwarelösung realisiert, die die Verschlüsselung und einen Teil der Überprüfung der Nachrichten übernimmt, die im NOOTS versendet werden. Die interne Struktur des NOOTS wird so durch die SAK gekapselt, angeschlossene Stellen werden entlastet und müssen beispielsweise bei Änderungen an den im NOOTS verwendeten Verschlüsselungsalgorithmen lediglich ihren SAK aktualisieren.

Möchte eine Stelle einen Nachweis abrufen oder eine Nachweisanfrage beantworten, übergibt sie ihre Anfrage bzw. Antwort an ihren SAK, der die weiteren Schritte übernimmt. Die SAK sichern die Nachrichtenübertragung zusätzlich zu einer TLS-Verschlüsselung mittels Inhaltsdatenverschlüsselung ab. Darüber hinaus führen sie für die nachweisabrufende Stelle eine formale Schemavalidierung der eingehenden Nachrichten durch und bieten die Möglichkeit der Einbindung eines Virencanners. Für die nachweisliefernde Stelle führen die SAK verschiedene Prüfungen durch, um die Authentizität der Anfrage und die abstrakte Berechtigung zum Nachweisabruf zu überprüfen. Im NOOTS ist hierzu ein Zero-Trust-Konzept implementiert worden, um bei der Vielzahl der angebundenen Stellen für größtmögliche Sicherheit zu sorgen. Darüber hinaus gibt es im NOOTS ein zentrales Monitoring, das Auffälligkeiten detektieren und nötigenfalls durch kurzfristige Abschaltung einzelner Akteure Schaden abwenden kann.

Durch die SAK können die angebundenen Stellen nach Zuhilfenahme der zentralen NOOTS-Komponenten direkt miteinander kommunizieren, um Nachweise auszutauschen. Dadurch entsteht ein Netzwerk, das durch diese SAK aufgespannt wird und eine Vielzahl von Registern, Spiegelregistern, Abrufportalen, Onlinediensten und perspektivisch auch Fachverfahren miteinander verbindet.

Einem NOOTS Teilnehmer sind immer genau eine fach- und eine betriebsverantwortliche Stelle zugeordnet. Erstere hat die fachliche Hoheit über ihre Verfahren und Daten, letztere betreibt die zugehörigen digitalen Dienste und schließt den Teilnehmer mittels eines SAK an das NOOTS an. Der Anschluss eines Teilnehmers an das NOOTS mittels eines SAK stellt hierbei eine potenzielle Quelle für Informationssicherheitsrisiken dar und muss dementsprechend abgesichert werden, damit das NOOTS nicht von außen kompromittiert wird. Die vorliegende Technische Richtlinie definiert daher Informationssicherheitsanforderungen, die von den fach- und betriebsverantwortlichen Stellen der NOOTS Teilnehmer zwingend umzusetzen sind. Dies ist nötig zur Absicherung der Übertragung der Daten und Nachweise, die zu einem erheblichen Teil personenbezogene Daten enthalten, häufig sogar mit hohem und sehr hohem Schutzbedarf, und angesichts der Vielzahl der Akteure.

Die Technische Richtlinie unterscheidet hierbei zwischen verschiedenen Anschlussklassen, an die unterschiedliche Anforderungen zu stellen sind. Diese Anschlussklassen sind die nachweisanfordernden und die nachweisliefernden Stellen. Die unterschiedlichen Anforderungen an diese beiden Anschlussklassen beruhen darauf, dass die für diese beiden Klassen jeweils zur Verfügung gestellten SAK unterschiedliche Ausprägungen haben. Die vorliegende Richtlinie listet zunächst die Anforderungen auf, die für beide Anschlussklassen gleichermaßen gelten, und geht danach auf spezielle Anforderungen der beiden Klassen ein. Viele anzuschließende Stellen fungieren sowohl als Data Consumer als auch als Data Provider und müssen daher die Gesamtheit an Anforderungen umsetzen.

Als Hilfestellung zur Umsetzung von IT-Grundschutz durch die anzubindenden Stellen erstellt das Bundesverwaltungsamt ein IT-Grundschutzprofil. Zusätzlich enthalten die Anschlusskonzepte für Data Consumer und Data Provider, die in den Architekturdokumenten des NOOTS (AD-NOOTS (2)) veröffentlicht sind, eine Darstellung der technischen Voraussetzungen für einen Anschluss an das NOOTS.

Informationssicherheitsanforderungen, die sich an die zentralen NOOTS-Komponenten und die Hersteller der SAK wenden, sind in TR-03176 (3) zu finden. In TR-03172 (4) sind Anforderungen zu finden, die sich an den Portalverbund und die an ihn angebundenen IT-Komponenten wie Onlinedienste und Datenschutzcockpit richten.

1.2 Zielgruppe

Die Zielgruppe umfasst die Akteure, die den technischen Anschluss an das NOOTS vornehmen, die Einhaltung der Informationssicherheitsanforderungen gewährleisten und den Datenverkehr über das NOOTS abwickeln.

Die vorrangigen Zielgruppen für die Informationssicherheitsanforderungen für den Anschluss an das NOOTS sind:

- Bundesländer und ihre IT-Verantwortlichen,
- Kommunen und Gemeinden mit ihren IT-Verantwortlichen,
- IT-Dienstleister im Auftrag der öffentlichen Verwaltung,
- Öffentliche Verwaltungen, deren Onlinedienste oder Fachverfahren als Data Consumer (DC) agieren,
- Öffentliche Verwaltungen und perspektivisch weitere Stellen, deren Register oder Abrufportale als Data Provider (DP) auftreten.

1.3 Aufbau der Technischen Richtlinie

In der vorliegenden Technischen Richtlinie werden zunächst die verwendeten Begriffe und darauf folgend die Anschlussklassen definiert. Die Definition der Anschlussklassen differenziert danach, welche Rolle eine Stelle (Data Consumer (DC) oder Data Provider (DP)) im Nachweisabrufprozess erfüllt.

Danach werden die Informationssicherheitsanforderungen aufgelistet, die alle Stellen umzusetzen haben, die sich an das NOOTS anbinden. Diese gliedern sich in Anforderungen bezüglich

- Umsetzung von IT-Grundschutz
- Installation des SAK
- Betrieb des SAK
- Verfügbarkeit des SAK
- Anforderungen an DCs und DPs

Darauf folgen Anforderungen, die nur von der jeweiligen Anschlussklasse – DC oder DP – umzusetzen sind.

Abschließend folgen Abkürzungs- und Literaturverzeichnis.

1.4 Schlüsselwörter

In der vorliegenden Technischen Richtlinie werden Anforderungen als Ausdruck normativer Festlegungen durch die in Großbuchstaben geschriebenen deutschen Schlüsselworte MUSS/MÜSSEN, DARF NICHT/DÜRFEN NICHT, SOLLTE/SOLLTEN entsprechend gekennzeichnet.

In den Anforderungen werden die in Versalien geschriebenen Modalverben „SOLLTE“ und „MUSS“ in ihren jeweiligen Formen sowie den zugehörigen Verneinungen genutzt, um deutlich zu machen, wie die jeweiligen Anforderungen zu interpretieren sind. Die hier genutzte Definition basiert auf RFC 2119 (2).

MUSS/DARF NUR:	Dieser Ausdruck bedeutet, dass es sich um eine Anforderung handelt, die unbedingt erfüllt werden muss (uneingeschränkte Anforderung).
DARF NICHT/DARF KEIN:	Dieser Ausdruck bedeutet, dass etwas in keinem Fall getan werden darf (uneingeschränktes Verbot).
SOLLTE:	Dieser Ausdruck bedeutet, dass eine Anforderung normalerweise erfüllt werden muss, es aber Gründe geben kann, dies doch nicht zu tun. Dies muss aber sorgfältig abgewogen und stichhaltig begründet werden.
SOLLTE NICHT/SOLLTE KEIN:	Dieser Ausdruck bedeutet, dass etwas normalerweise nicht getan werden sollte, es aber Gründe gibt, dies doch zu tun. Dies muss aber sorgfältig abgewogen und stichhaltig begründet werden.
KANN	Dieser Ausdruck bedeutet, dass eine bestimmte Umsetzung gewählt werden kann. Diese muss allerdings angezeigt werden.

2 Begriffsdefinitionen

Im Rahmen dieser Technischen Richtlinie werden Begriffe verwendet, die wie folgt definiert werden:

Begriff	Definition
Basisdaten	Stammdatensatz über eine natürliche Person oder ein Unternehmen im Sinne des § 4 IDNrG oder § 3 UBRegG
Basisregister	Register, welches Basisdaten vorhält. Es existiert das Basisregister des BZSt für natürliche Personen sowie das Basisregister des StBA für Unternehmen.
Bundeseinheitliche Wirtschaftsnummer für Unternehmen (beWiNr)	Nummer, die einem Unternehmen nach § 2 UBRegG zugeordnet wird. Sie ist identisch mit der Wirtschafts-Identifikationsnummer (W-IDNr.)
Data Consumer (DC)	Technisches System, das Nachweisdaten anfordert. Im Verantwortungsbereich des Data Consumers befindet sich ein sicherer Anschlussknoten (SAK) und ggf. ein Data Consumer Adapter (DCA).
Data Provider (DP)	Technisches System, das Nachweisdaten zum Abruf bereitstellt. Im Verantwortungsbereich des Data Providers befindet sich ein sicherer Anschlussknoten (SAK) und ggf. ein Data Provider Adapter (DPA).
Ende-zu-Ende-Verschlüsselung	Als Ende-zu-Ende-Verschlüsselung bezeichnet man eine Verschlüsselung der Fachnachricht, die gewährleistet, dass niemand außer dem Empfangs- und Sendesystem Kenntnis über den Inhalt der Nachricht erwerben kann. Insbesondere wird die Verschlüsselung der Fachdaten nicht an zwischengeschalteten Systemen aufgebrochen. Im NOOTS liegen die Enden der Verschlüsselung in den SAK. Dies ist notwendig, da die SAK die Inhalte sonst nicht prüfen könnten. Für die Übertragung zum DC bzw. DP, der den SAK betreibt, ist eine erneute TLS-Verschlüsselung vorgeschrieben.
Fachverfahren	IT-gestützter Vorgang zur Bearbeitung eines Antrags durch die öffentliche Verwaltung im Kontext der Antragstellung gemäß OZG. Dies kann vorbereitende Schritte wie eine Anti-Virus-Prüfung beinhalten, soweit sie technisch eng an die fachliche Verarbeitung gebunden sind.
IAM für Behörden	Die Aufgabe, NOOTS-Teilnehmer zu identifizieren und zu authentifizieren übernimmt die zentrale NOOTS-Komponente „Identity and Access Management für Behörden“.
Identitätsdatenabruf (kurz: IDA)	Verfahren zum Abruf der Identifikationsnummer und anderer Basisdaten aus der Steuer-ID-Datenbank des Bundeszentralamtes für Steuern

Begriff	Definition
IDM für Personen	Kurz für „Identitätsmanagement für Personen“. Zentrale NOOTS-Komponente, die mit Hilfe des IDA-Verfahrens die Identifikationsnummer zu einer natürlichen Person ermittelt.
Identifikationsnummer (IDNr.)	Die Identifikationsnummer nach § 139b der Abgabenordnung. Wird nach Identifikationsnummerngesetz als zusätzliches Ordnungsmerkmal in dort angegebenen Registern eingeführt, um eine natürliche Person eindeutig zu identifizieren.
NOOTS-Teilnehmer	Als Teilnehmer des NOOTS werden die über Sichere Anschlussknoten angeschlossenen Data Provider und Data Consumer bezeichnet.
Onlinedienst	Digitaler Service, um Verwaltungsleistungen zu beantragen. In der Regel werden die Eingaben durch ein Fachverfahren bearbeitet.
Register	Ein Register ist eine Komponente, mit der die Datenbestände in der öffentlichen Verwaltung elektronisch geführt werden. Im Rahmen dieser TR umfasst der Begriff „Register“ auch Spiegelregister oder Abrufportale, wenn diese bei Datenabrufen an die Stelle der eigentlichen Register treten.
Registerdatennavigation (RDN)	Die Registerdatennavigation (RDN) ist eine zentrale NOOTS-Komponente, die die Zuständigkeiten und Verbindungsparameter der angeschlossenen Register bereitstellt.
Sicherer Anschlussknoten (SAK)	Die Sicheren Anschlussknoten sind Komponenten, die für den Anschluss der NOOTS-Teilnehmer (Data Consumer und Data Provider) an das NOOTS verwendet werden. Sie übernehmen Aufgaben bei der Kommunikation mit den zentralen NOOTS-Komponenten und der Prüfung eingehender Nachrichten und sind für die Ver- und Entschlüsselung zuständig. Sie werden vom Bundesverwaltungsamt als betriebsverantwortliche Stelle des NOOTS zur Verfügung gestellt, aber von den Data Consumern und Data Providern in Eigenverantwortung betrieben.
Token	Token sind Datenmengen, die im NOOTS verwendet werden, um Eigenschaften zu attestieren, die eine andere Stelle geprüft hat. Sie sind im NOOTS so gestaltet, dass sie von weiteren Komponenten und NOOTS-Teilnehmern überprüft werden können.

Begriff	Definition
Transportverschlüsselung	Als Transportverschlüsselung bezeichnet man die Verschlüsselung einer Nachricht auf der Transportebene, beispielsweise mittels TLS. Zusammen mit der Inhaltsverschlüsselung bildet sie im NOOTS die Ende- zu- Ende-Verschlüsselung zwischen SAK.
Vermittlungsstelle (VS)	Die Aufgabe, bei Nachweisabrufen eine abstrakte Berechtigungsprüfung durchzuführen, übernimmt im NOOTS die Vermittlungsstelle (VS).
Verzeichnis	Eine Datenbank oder ein Verzeichnisdienst, welches in der Regel der weiträumigen Bekanntgabe bestimmter Informationen wie beispielsweise von Zertifikaten oder technischen Verbindungsparametern dient. Ein Beispiel hierfür ist das Diensteverzeichnis der öffentlichen Verwaltung (DVDV).
XBasisdaten	Standard zum Abrufen von Basisdaten über natürliche Personen
XDatenschutzcockpit	Standard zum Abrufen von Abrufprotokollen aus Registern zwecks Darstellung im Datenschutzcockpit
XNachweis	Standard zum Abrufen von Nachweisen
XUnternehmen.Basisregister	Standard zum Abrufen von Basisdaten über Unternehmen

3 Der Nachweisabrufprozess unter Verwendung des NOOTS

Das Nationale Once-Only Technical System (NOOTS) stellt eine Transportinfrastruktur dar, die perspektivisch tausende Register mit Onlinediensten und Fachverfahren verbinden soll, um einen Datenaustausch zu ermöglichen. Insbesondere soll es diese Vernetzung überflüssig machen, dass Bürgerinnen, Bürger und Unternehmen Nachweise, die an einer Stelle der öffentlichen Verwaltung bereits vorliegen, ein weiteres Mal selbst erbringen müssen (Once-Only-Prinzip). Über einen eDelivery Access Point (eDAP) und eine Intermediäre Plattform (IP) kann das NOOTS mit seinem europäischen Pendant, dem EU-OOTS verknüpft werden, so dass einerseits Nachweise abgerufen werden können, die im EU-Ausland vorliegen, und andererseits aus dem EU-Ausland Nachweise aus deutschen Registern bezogen werden können, sofern eine entsprechende Berechtigung und Authentifizierung gegeben ist. Der IT-Planungsrat hat

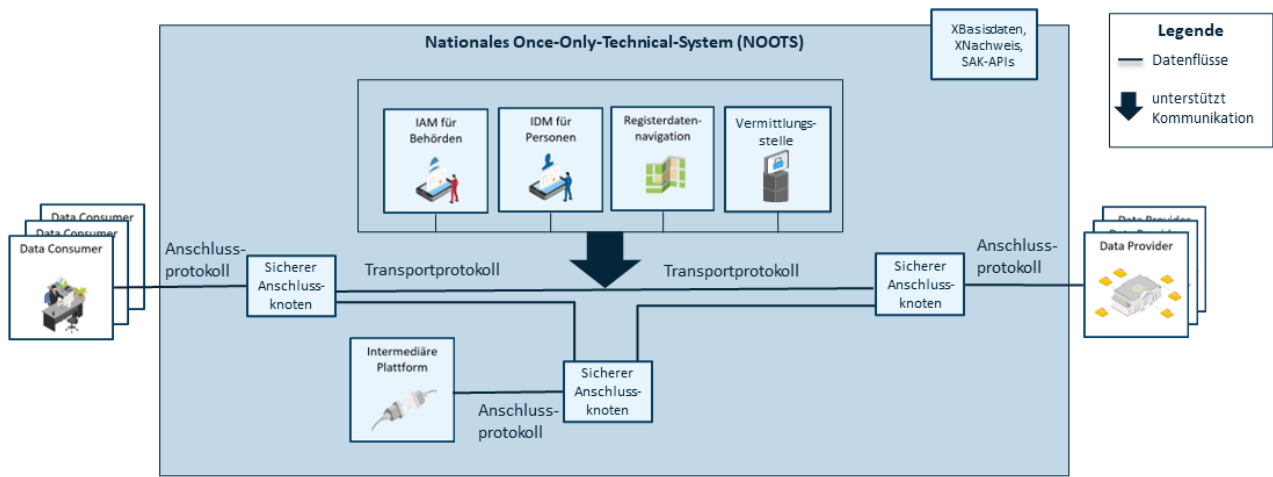


Abbildung 1: Technischer Kontext Transportinfrastruktur des NOOTS (19).

Hinweis: Die unterschiedlichen Data Consumer und Data Provider betreiben jeweils ihre eigenen Sicherer Anschlussknoten, dies wird in dieser schematischen Darstellung nicht wiedergegeben.

mit Beschluss 2022/39 vom 10. November 2022 festgelegt, dass von der Möglichkeit der Nutzung intermediärer Plattformen Gebrauch zu machen ist.

Ein Nachweisabruf startet aus Sicht des NOOTS dabei stets bei einem Data Consumer (DC). Dieser DC kann ein Onlinedienst oder perspektivisch auch ein Fachverfahren sein, das einen Nachweis benötigt. Beispielsweise kann sich bei einem mit dem NOOTS verbundenen Onlinedienst eine Person eingeloggt haben, um einen Onlineantrag zu stellen, dem ein bestimmter Nachweis als Anlage beigefügt werden muss. Die Person kann dann die Möglichkeit nutzen, den benötigten Nachweis über das NOOTS automatisiert abzurufen und nach Sichtung des übermittelten Dokuments dieses in das Onlineverfahren einzubringen. Die technischen Systeme, die die angefragten Nachweise liefern, werden im Kontext des NOOTS als Data Provider (DP) bezeichnet. Ein DP kann beispielsweise ein Register oder ein Abrufportal sein. Eine Sonderrolle spielt die Intermediäre Plattform des NOOTS, die im NOOTS sowohl als DC als auch als DP auftritt.

Alle Nachweisanfragen werden über die Sicherer Anschlussknoten (SAK) der betreffenden DC und DP abgewickelt (vgl. Abbildung 1). Die SAK werden allen NOOTS-Teilnehmern vom BVA in ihrer Rolle als betriebsverantwortliche Stelle des NOOTS zur Verfügung gestellt. Aus Sicht der NOOTS-Teilnehmer kapseln die SAK die interne Struktur des NOOTS. Im Rahmen einer Nachweisabfrage, welche durch einen DC angestoßen wird, ruft der SAK des DC die zentralen NOOTS-Komponenten IAM für Behörden, Registerdaten-naviga-tion und Vermittlungs-stelle sowie ggf. IDM für Personen/Unternehmen auf. Erst im Anschluss erfolgt der eigentliche Verbindungsaufbau mit dem SAK des DP. Der Ablauf dieser Aufrufe wird im Folgenden in Kurzform beschrieben.

Im ersten Schritt des Nachweisabrufs kontaktiert der DC über seinen SAK die zentrale NOOTS-Komponente IAM für Behörden. Werden der DC und sein SAK als berechtigt erkannt, so erhält der SAK des DC ein Zugriffstoken, das es ihm ermöglicht, die nächsten Schritte des Nachweisabrufs durchzuführen.

Im nächsten Schritt kontaktiert der SAK des DC die Registerdatennavigation, damit diese den für die Nachweislieferung zuständigen Data Provider (DP) ermittelt. Die entsprechenden Informationen werden dem SAK des DC im Zuständigkeitstoken zurückgeliefert.

In manchen Registern wird die IDNr. als eindeutiges Ordnungsmerkmal für die Zuordnung der Daten zu natürlichen Personen verwendet. Handelt es sich um eine Anfrage an eines dieser Register, so kann der DC über seinen SAK als nächstes beim IDM für Personen über das IDA-Verfahren die IDNr. der Person abfragen. Handelt es sich um eine Anfrage eines Unternehmens, kann die beWiNr. angefragt werden. Über die Umsetzung der dafür zuständigen NOOTS-Komponente IDM für Unternehmen ist zum Zeitpunkt der Veröffentlichung dieser Technischen Richtlinie noch nicht abschließend entschieden worden.

Im nächsten Schritt des Nachweisabrufs kontaktiert der SAK des DC die Vermittlungsstelle, welche überprüft, ob eine abstrakte Berechtigung für den angefragten Nachweisabruf vorliegt. Wird dieser Schritt erfolgreich durchgeführt, so erhält der SAK des DC von der Vermittlungsstelle das sog. Abruftoken. In diesem Fall folgt im Anschluss die Abfrage der Verbindungsparameter des SAK des DP bei der Registerdatennavigation.

Wenn alle Token erfolgreich ausgestellt worden sind, versendet der SAK des DC die Nachweisanfrage, angereichert mit den erhaltenen Token, an den SAK des DP. Zwischen dem SAK des DC und dem SAK des DP wird hierbei eine Ende-zu-Ende-Verschlüsselung eingesetzt. Zusätzlich zur Transportverschlüsselung wird eine Inhaltsdatenverschlüsselung mit Krypto-Containern verwendet, um die Unabhängigkeit von darunterliegenden Netzwerken zu gewährleisten und die Grundlage für Krypto-Agilität und Post-Quanten-Kryptographie zu schaffen.

Der SAK des DP überprüft die übermittelte Nachweisanfrage und die mitgelieferten Token und leitet im Erfolgsfall beides an den DP weiter. Bei erfolgreicher Verarbeitung der Nachweisanfrage durch den DP wird die Antwortnachricht mit angefragtem Nachweis über den gleichen Weg, d.h. über SAK des DP und SAK des DC, an den DC zurückgesendet.

Auch bei der Rückantwort übernehmen die SAK die Verschlüsselung nach dem Stand der Technik. Die SAK werden zwar vom Bundesverwaltungsamt als betriebsverantwortliche Stelle des NOOTS zentral zur Verfügung gestellt, die betriebliche Verantwortung liegt aber bei den entsprechenden DCs oder DPs bzw. den durch diese beauftragten Stellen. Im Laufe des gesamten Nachweisabrufes erlangen die zentralen NOOTS-Komponenten weder Kenntnis von den Inhalten der Nachweisanfrage – abgesehen von den Daten, die nötig sind, um das zuständige Register zu ermitteln – noch von den übermittelten Nachweisen.

Das NOOTS implementiert bei jeder Kontaktierung von Komponenten durch andere Komponenten eine gegenseitige Authentifizierung anhand mehrerer technischer Artefakte wie Token und Zertifikate. Die verschiedenen Berechtigungstoken werden an jede Stelle weitergeleitet, für die sie relevant sind, so dass jede Komponente die vorangegangenen Schritte im Sinne von Zero Trust selbst verifizieren kann, ohne auf eine implizierte Vertrauensbeziehung angewiesen zu sein. Auch dem DP werden die relevanten Token zum Nachprüfen zur Verfügung gestellt.

Als weitere Säule der Sicherheitsarchitektur ist die zentrale Monitoring-Stelle des NOOTS hervorzuheben, welche die Aktivitäten im NOOTS kontinuierlich überwacht und bei Auffälligkeiten Maßnahmen wie eine kurzfristige Sperre von NOOTS-Teilnehmern veranlassen kann.

4 Definition Anschlussklassen

An das NOOTS können sich verschiedene Teilnehmer anschließen. Anschlussklassen sind dabei Kategorien von Teilnehmern, die vergleichbare Rollen ausführen und für die daher auch gleiche Anforderungen beim Anschluss an das NOOTS gelten. Zum jetzigen Zeitpunkt werden lediglich zwei Anschlussklassen unterschieden. Dies könnte in der Zukunft weiter ausdifferenziert werden, wenn sich herausstellen sollte, dass eine weitere Unterteilung aufgrund unterschiedlicher Schutzanforderungen der übertragenen Daten und, daraus resultierend, unterschiedliche Anforderungsniveaus bezüglich der Informationssicherheit erforderlich werden. Folgende Anschlussklassen werden aktuell betrachtet:

1. Data Consumer (DC),
2. Data Provider (DP).

In der Tabelle sind diese Anschlussklassen zusammen mit exemplarischen Ausprägungen dargestellt.

Anschlussklasse	Beschreibung
Data Consumer (DC)	NOOTS-Teilnehmer, die Nachweise aus Registern der öffentlichen Verwaltung abrufen.
- Onlinedienste	Onlinedienste der öffentlichen Verwaltung, die Nachweise abrufen.
- Fachverfahren	Fachverfahren der öffentlichen Verwaltung, die Nachweise abrufen.
-Intermediäre Plattform (IP) in der Rolle des DC	System zur Vermittlung von Nachweisabrufen im europäischen Kontext.
Data Provider (DP)	NOOTS-Teilnehmer, die Nachweise bereitstellen. Der Anschluss erfolgt über technische Registerstrukturen.
- Zentrale Register	Register auf Bundes- oder Landesebene mit zentraler Infrastruktur (z.B. Kraftfahrtbundesamt, Bundesagentur für Arbeit).
- Dezentrale Register	Verteilte Register, die Nachweise liefern, ohne zentrale Struktur, z. B. kommunale Register.
- Basisregister	Spezialisierte Register für Unternehmens- oder Personenbasisdaten, z.B. das Basisregister für Unternehmen oder das Identifikationsnummernregister des Bundeszentralamts für Steuern
- Spiegelregister	Spiegelregister sind zentrale Zugangspunkte zu dezentralen Registern. Sie halten Kopien der Daten der dezentralen Register vor und stellen sie zum Abruf bereit.
- Abrufportal	Abrufportale sind zentrale Zugangspunkte zu dezentralen Registern, die selbst keine Registerdaten vorhalten. Sie können Nachweisanfragen automatisiert bearbeiten und unterstützen so dabei, die angefragten Daten aus dem dezentralen Register an die anfragende Stelle zu übermitteln.

Anschlussklasse	Beschreibung
- Intermediäre Plattform (IP) in der Rolle des DP	System zur Vermittlung von Nachweisabrufen im europäischen Kontext.

Es ist auch möglich, dass ein NOOTS-Teilnehmer mehrere Anschlussklassen betreibt. Dann nimmt dieser entsprechend mehrere Rollen gleichzeitig ein. Die Intermediäre Plattform agiert u.a. in den Rollen des Data Consumer und Data Provider, indem sie Aufgaben und Nachweisbereitstellung sowohl delegiert als auch vermittelt. National können NOOTS-Teilnehmer verschiedene dieser Rollen vereinen, beispielsweise als Betreiber von Fachverfahren (Data Consumer) und als Bereitsteller von Daten (Data Provider).

Dabei bleiben die Verantwortlichkeiten der jeweiligen Anschlussklasse und Rolle in ihrem Aufgabenbereich erhalten.

Konkret macht diese Technische Richtlinie Vorgaben, deren Teile entsprechend der folgenden Tabelle verschiedene Stellen adressieren:

Vorgaben, gültig für:	Betriebsverantwortliche Stelle des SAK	Data Consumer	Data Provider
Kapitel 5	X	X	X
Kapitel 6	X		
Kapitel 7.1		X	X
Kapitel 7.2			X
Kapitel 7.3		X	

5 Vorgaben zur Umsetzung von IT-Grundschutz und allgemeine Anforderungen an den Betrieb

Die NOOTS-Architektur verfolgt das Ziel, ein Zero-Trust-Konzept in dem verteilten Informationsverbund umzusetzen. Zusätzlich zur Einrichtung eines Systems aus Policy Decision Points und Policy Enforcement Points, die die Einhaltung der Regeln des NOOTS überprüfen bzw. durchsetzen, bedeutet Zero Trust in diesem Kontext auch, dass es keine singulären, impliziten Vertrauensstellen innerhalb des NOOTS gibt. Die Kommunikation zwischen den Teilnehmern und die Berechtigung dazu wird über gesiegelte Tokens abgesichert, die von den beteiligten Stellen unabhängig überprüft werden können. Zusätzlich zu dieser Prüfung, die vor jedem Datenaustausch stattfindet, überwacht ein Monitoring-System das NOOTS und kann beim Entdecken von Auffälligkeiten oder Unregelmäßigkeiten kurzfristig Komponenten von der Teilnahme am NOOTS ausschließen, bis die Ursache aufgeklärt ist. Dies kann beispielsweise durch die Nichtausstellung eines Zugriffstokens für den entsprechenden NOOTS-Teilnehmer auf einfache Weise erfolgen.

Die Sicheren Anschlussknoten (SAK) nehmen bei der Absicherung des NOOTS eine wesentliche Rolle ein. Auf Seiten des Data Consumers (DC) veranlasst der SAK das Ausstellen der verschiedenen Zugriffs- und Berechtigungstoken, bündelt diese mit der Nachweisabfrage an den Data Provider (DP) und verschlüsselt die Kommunikation für den gewünschten DP. Beim Eintreffen der Rückantwort führt der SAK des DC die Prüfung der Nachricht auf Konformität und mittels eines eingebundenen Virenschanners auf Schadcode durch. Auf Seiten des DPs prüft der SAK die übermittelten Token auf Gültigkeit, bevor die eigentliche Anfrage entschlüsselt und an den DP samt Zugriffs- und Berechtigungstoken weitergeleitet wird. Der DP wird dadurch in die Lage versetzt die Anfrageberechtigung unabhängig zu prüfen, bevor eine Antwort erstellt und zurückgeliefert wird.

Die SAK werden vom Bundesverwaltungsamt als betriebsverantwortliche Stelle des NOOTS erstellt und mit Updates und Patches versorgt. Das Einspielen der jeweiligen Aktualisierungen ist Aufgabe der betriebsverantwortlichen Stelle des SAK. Jedoch führt ein Verwenden veralteter SAK-Versionen zwangsläufig dazu, dass der betreffende NOOTS-Teilnehmer nicht mehr am Datenaustausch teilnehmen kann, bis der von ihm betriebene SAK sich wieder auf dem aktuellen Stand befindet.

Die Gesamtheit der im NOOTS und in den SAK bereits etablierten Sicherheitsmechanismen führt dazu, dass die Informationssicherheitsanforderungen, die an die einzelnen über einen SAK an das NOOTS angeschlossenen Teilnehmer (DCs und DPs) zu stellen sind, stark reduziert werden. Dennoch sind die im Folgenden aufgelisteten Anforderungen Grundvoraussetzungen für ein funktionierendes, verlässliches und sicheres System, das Daten mit teils hohem und sehr hohem Schutzbedarf transportiert. Die folgenden Anforderungen sind daher von den betriebsverantwortlichen Stellen aller NOOTS-Teilnehmer (DC, DP und betriebsverantwortliche Stellen der SAK) umzusetzen.

5.1 Anforderungen zur Umsetzung von IT-Grundschutz

- [G.1] Die betriebsverantwortliche Stelle trägt ab dem SAK die Verantwortung für die Informationssicherheit. Sie MUSS durch Umsetzung der hier vorliegenden Sicherheitsanforderung sowie ggf. notwendiger weiterer nutzerspezifischer Maßnahmen sicherstellen, dass von dem von ihr betriebenen SAK, DC oder DP keine Gefährdung für die NOOTS-Infrastruktur oder andere Teilnehmer ausgeht.
- [G.2] Die BSI-Standards 200-1 (5), 200-2 (6) und 200-3 (7) oder die Vorgaben der ISO/IEC 27001 (8) SOLLTEN in der jeweils geltenden Fassung umgesetzt werden. Hierzu SOLLTE mindestens die Standard-Absicherung für den betreffenden Informationsverbund gewählt werden. Darüber hinaus SOLLTEN eine Risikoanalyse durchgeführt und gegebenenfalls daraus abgeleitet zusätzliche Absicherungsmaßnahmen getroffen werden, wenn der SAK aufgrund der DCs oder DPs, für die er tätig ist, Daten mit sehr hohem Schutzbedarf transportiert.

[G.3] Insbesondere MÜSSEN die folgenden IT-Grundschutzbausteine in der Standardabsicherung umgesetzt werden. Dies gilt auch, falls in [G.2] eine andere Methodik als der IT-Grundschutz des BSI gewählt wurde.

ISMS.1	Sicherheitsmanagement
ORP.1	Organisation
ORP.2	Personal
ORP.3	Sensibilisierung und Schulung zur Informationssicherheit
ORP.4	Identitäts- und Berechtigungsmanagement
ORP.5	Compliance Management (Anforderungsmanagement)

CON.1	Kryptokonzept
CON.2	Datenschutz
CON.3	Datensicherungskonzept
CON.6	Löschen und Vernichten
CON.7	Informationssicherheit auf Auslandsreisen
CON.8	Software-Entwicklung
CON.9	Informationsaustausch
CON.10	Entwicklung von Webanwendungen

OPS.1.1.1	Allgemeiner IT-Betrieb
OPS.1.1.2	Ordnungsgemäße IT-Administration
OPS.1.1.3	Patch- und Änderungsmanagement
OPS.1.1.4	Schutz vor Schadprogrammen
OPS.1.1.5	Protokollierung
OPS.1.1.6	Software-Tests und -Freigaben
OPS.1.1.7	Systemmanagement
OPS.1.2.2	Archivierung
OPS.1.2.4	Telearbeit
OPS.1.2.5	Fernwartung
OPS.1.2.6	NTP-Zeitsynchronisation

DER.1	Detektion von sicherheitsrelevanten Ereignissen
DER.2.1	Behandlung von Sicherheitsvorfällen
DER.2.2	Vorsorge für die IT-Forensik
DER.2.3	Bereinigung weitreichender Sicherheitsvorfälle
DER.3.1	Audits und Revisionen
DER.4	Notfallmanagement

- [G.4] Da der Sichere Anschlussknoten (SAK) sowohl in einem eigenen, physisch vorhandenen Server als auch in der Cloud installiert werden kann, sind aus den folgenden Bausteinen die entsprechend zutreffenden auszuwählen. Die zutreffenden Bausteine MÜSSEN in der Standardabsicherung umgesetzt werden:
- INF.1 Allgemeines Gebäude
 - NF.12 Verkabelung
 - INF.2 Rechenzentrum sowie Serverraum
 - NET.3.1 Router und Switches
 - NET.3.2 Firewall
 - SYS.2.1 Allgemeiner Client
 - NET.1.1 Netzarchitektur und -design
 - NET.1.2 Netzmanagement
 - OPS.2.2 Cloud-Nutzung
 - OPS.2.3 Nutzung von Outsourcing
- [G.5] Der BSI-Standard 200-4 (9) oder die Vorgaben der ISO-Norm 22301:2019 (10) SOLLTE in der jeweils geltenden Fassung umgesetzt werden. Schnittstellen zu angeschlossenen Diensten SOLLTEN berücksichtigt werden.
- [G.6] Die jeweilige betriebsverantwortliche Stelle MUSS sicherstellen, dass nur berechtigte Teilnehmer auf die Infrastruktur des NOOTS zugreifen dürfen. Betriebsverantwortliche und fachverantwortliche Stellen MÜSSEN berechtigte Teilnehmer bestimmen.
- [G.7] Fach- und betriebsverantwortliche Stellen MÜSSEN Verfügbarkeitsanforderungen an ihre Systeme dokumentieren und die Architektur der beteiligten Systemkomponenten daran ausrichten. Bei der Ermittlung der Verfügbarkeitsanforderungen MUSS die potentielle Nutzerbasis sowie eventuelle Lastspitzen durch Stichtage berücksichtigt werden. Es SOLLTEN Lasttests durchgeführt werden um die Skalierbarkeit und Stabilität der Infrastruktur zu gewährleisten.

6 Vorgaben bezüglich SAK

Die betriebsverantwortlichen Stellen der Data Consumer und Data Provider sind verpflichtet sich über die vom Bundesverwaltungsamt (BVA) zur Verfügung gestellten Sicheren Anschlussknoten (SAK) mit dem NOOTS zu verbinden. Das BVA als betriebsverantwortliche Stelle des NOOTS trägt hierbei die Verantwortung dafür, dass die als Software ausgestalteten SAK den sicherheitstechnischen Vorgaben der TR-03176 (3) genügen.

Mit den SAK wird sichergestellt, dass innerhalb der Transportinfrastruktur des NOOTS unabhängig von den einzelnen NOOTS-Teilnehmern die Einhaltung zentraler Sicherheitsvorgaben gewährleistet wird, wie die Validierung der Daten, die Prüfung gültiger Zugriffsberechtigungen oder das Vorliegen einer abstrakten Berechtigung der Vermittlungsstelle. Zusätzlich können zukünftige umzusetzende Sicherheitsanforderungen (z.B. in Bezug auf kryptografische Verfahren) innerhalb des NOOTS in der Regel ohne direkte Abhängigkeit von den NOOTS-Teilnehmern umgesetzt werden. Die NOOTS-Teilnehmer werden von diesen Aufgaben entlastet.

Von Seiten der betriebsverantwortlichen Stellen sind die folgenden, den Betrieb eines SAK betreffenden Anforderungen zu erfüllen. Diese Anforderungen sind als Ergänzung zu den in Kapitel 5 genannten IT-Grundsichtbausteinen zu sehen. Insbesondere ergibt sich aus dem Baustein ORP.2, dass für den Betrieb eines SAK auf die Vertrauenswürdigkeit des eingesetzten Personals zu achten ist.

Da die vom BVA fachlich verantwortete Intermediäre Plattform auch über SAK an das NOOTS angeschlossen wird, betreffen die in diesem Kapitel formulierten Anforderungen auch die entsprechenden fach- und betriebsverantwortlichen Stellen.

6.1 Vorgaben zu Installation und Inbetriebnahme des SAK

Über die Vorgaben des IT-Grundsichtes hinaus sind bei der Installation und Inbetriebnahme eines SAK spezifische Anforderungen zu beachten:

- [SAK.1.1] Für jede einzelne betriebene SAK-Instanz MUSS genau eine betriebsverantwortliche Stelle zuständig sein.
- [SAK.1.2] Für jeden SAK, der für einen DP betrieben wird, MUSS genau eine fachverantwortliche Stelle zuständig sein.
- [SAK.1.3] Für jeden SAK, der für einen DC betrieben wird, KÖNNEN mehrere fachverantwortliche Stellen zuständig sein, falls die Mandantenfähigkeit genutzt wird. Die fachliche Zuständigkeit MUSS vor Inbetriebnahme geklärt sein.
- [SAK.1.4] Die Information über die betriebsverantwortliche Stelle eines SAK MUSS dem Bundesverwaltungsamt (BVA) als betriebsverantwortliche Stelle des NOOTS bekannt gemacht werden.
- [SAK.1.5] Die betriebsverantwortliche Stelle MUSS den SAK eines DP innerhalb seiner demilitarisierten Zone (vgl. IT-Grundsicht Baustein NET.1.1.A4 „Netztrennung in Zonen“ (11)) betreiben. Auf der Kommunikationsstrecke zwischen dem SAK des DP und dem Internet MUSS mindestens ein Paketfilter liegen.
- [SAK.1.6] Die im SAK entschlüsselten Inhaltsdaten MÜSSEN vor der Weiterverarbeitung durch einen Virens Scanner überprüft werden. Die Möglichkeit zur Einbindung eines Virens Scanners in den SAK SOLLTE hierfür genutzt werden.
- [SAK.1.7] Die fach- und die betriebsverantwortliche Stelle MÜSSEN sich und den von ihnen betriebenen SAK als Teilnehmer am NOOTS beim BVA registrieren. Bei allen Nachweisabrufen MÜSSEN die vorgesehenen und aktuellen Authentifizierungszertifikate sowohl von DC als auch von DP verwendet werden.
- [SAK.1.8] Jeder DC MUSS bei seinen Anfragen an das IAM für Behörden über ein für die Anbindung an das NOOTS dediziertes Signierzertifikat, welches den Vorgaben der TR-02102-1 (12) genügt, identifizierbar sein.

- [SAK.1.9] Für die Verwaltung des kryptografischen Materials MUSS mindestens das Security Level 1 gemäß der Key Lifecycle Security Requirements (13) eingehalten werden.
- [SAK.1.10] Das Einspielen (Deployment) der Softwarepakete und Updates in eine Produktivumgebung SOLLTE automatisiert und mit konsistenter Konfiguration stattfinden. Es KÖNNEN Tools von kontinuierlicher Integration (Continuous Integration) sowie kontinuierlicher Verteilung (Continuous Deployment) verwendet werden. Der Prozess des Einspielens SOLLTE manuell ausgelöst werden.
- [SAK.1.11] Die Gültigkeit der Signatur des Softwarepakets bzw. Quellcodes MUSS vor der Inbetriebnahme des SAK validiert werden. Releases DÜRFEN NUR eingespielt werden, wenn sie erfolgreich validiert worden sind.
- [SAK.1.12] Vor Inbetriebnahme eines SAK MUSS durch den DC bzw. DP, in dessen Auftrag er tätig werden soll, eine Abschätzung vorgenommen werden, mit welchem Durchsatz an Nachweisabrufen pro Zeiteinheit zu rechnen ist. Daraus SOLLTE eine Obergrenze definiert werden und diese dem Bundesverwaltungsamt bekannt gemacht werden, damit bei deren Überschreitung das zentrale Monitoring des NOOTS die entsprechenden DC temporär sperren kann.
- [SAK.1.13] Vor Inbetriebnahme MUSS die fachverantwortliche oder die betriebsverantwortliche Stelle eines SAK im Datenmanagementsystem DAMAS die notwendigen Daten anlegen.

6.2 Vorgaben an den Betrieb eines SAK

Über die Umsetzung der oben genannten Grundsatzbausteine hinaus gibt es spezielle Vorgaben an den Betrieb eines SAK, die insbesondere das Vorgehen bei auftretenden Fehlern oder Auffälligkeiten sowie den Umgang mit seiner Mandantenfähigkeit betreffen.

6.2.1 Allgemeine Vorgaben an den Betrieb eines SAK

- [SAK.2.1] Die fachverantwortliche oder die betriebsverantwortliche Stelle eines SAK MUSS die für ihren SAK im Datenmanagementsystem DAMAS des NOOTS hinterlegten Daten entsprechend der Vorgaben von DAMAS regelmäßig aktualisieren. Fach- und betriebsverantwortliche Stellen MÜSSEN untereinander festlegen, welche Stelle welche Aufgaben hierbei übernimmt.
- [SAK.2.2] Die betriebsverantwortliche Stelle eines SAK MUSS die für ihren SAK benötigten Zertifikate aktuell halten. Insbesondere MUSS sie eine entsprechende Aktualisierung durchführen, wenn es aufgrund einer Änderung der im NOOTS verwendeten kryptografischen Verfahren notwendig wird.

6.2.2 Protokollierung und Fehlerbehandlung

Das NOOTS besitzt ein zentrales Monitoringsystem. Es beruht darauf, dass jeder SAK bei jeder Interaktion mit den zentralen oder anderen dezentralen Komponenten des NOOTS eine Mitteilung über die Art und den Kommunikationspartner der Interaktion an die zentrale Monitoring-Komponente des NOOTS versendet.

Wenn das Monitoring Auffälligkeiten detektiert, wird der betreffende NOOTS-Teilnehmer automatisiert vom weiteren Datenaustausch über das NOOTS ausgeschlossen. In diesem Fall muss eine manuelle Klärung erfolgen, für die die Kontaktdaten der zuständigen Stelle im NOOTS bekannt sein müssen.

Auch Sicherheitsvorfälle bei der Stelle, die einen SAK betreibt, und bei einem DC oder DP, für den der SAK betrieben wird, betreffen das NOOTS und müssen unverzüglich nach Entdeckung einer Zentralstelle des NOOTS gemeldet werden, um Schaden vom restlichen NOOTS abzuwenden und die Daten und Nachweise zu schützen, die sich in den Registern befinden.

Daraus ergeben sich folgende Anforderungen an die Betreiber von SAK:

- [SAK.2.3] Die betriebsverantwortliche Stelle MUSS die Kommunikation zwischen dem SAK und dem zentralen Monitoring des NOOTS während der gesamten Nutzdauer des SAK ermöglichen.
- [SAK.2.4] Für die Übermittlung von Daten an die zentrale Monitoring Stelle MÜSSEN die Daten unter Beachtung der kryptografischen Vorgaben in TR-02102-1 (12) verschlüsselt und signiert werden.

- [SAK.2.5] Für jeden SAK MUSS innerhalb der Kommunikationsinfrastruktur des NOOTS ein Verweis auf eine Stelle vorliegen, die zur manuellen Klärung von Fehlern des von ihr verantworteten SAK innerhalb der durch das NOOTS vorgegebenen Frist zur Verfügung steht.
- [SAK.2.6] Die IDNr., andere identifizierende personenbezogene Daten sowie die bundeseinheitliche Wirtschaftsnummer DÜRFEN NICHT im Rahmen des geführten Protokolls gespeichert werden.
- [SAK.2.7] Sobald eine betriebsverantwortliche Stelle eines SAK oder eines DC oder DP Kenntnis über einen Sicherheitsvorfall erlangt, der sich in dem von ihr verantworteten Bereich ereignet hat, MUSS die dafür vorgesehene Stelle des NOOTS innerhalb der dafür vom NOOTS vorgegebenen Frist kontaktiert werden. Dafür MUSS der Reaktionsprozess bei Bekanntwerden einer Schwachstelle auf Basis ihrer Kritikalität im Sicherheitskonzept klar definiert sein. Der Reaktionsprozess MUSS allen Beteiligten bekannt sein.

6.2.3 Vorgaben zum Betrieb eines SAK mit mehreren Mandanten

Allen NOOTS-Teilnehmern, d.h. Data Consumern und Data Providern, ist genau eine fach- und eine betriebsverantwortliche Stelle zugeordnet. Einer Menge von Data Consumern mit derselben betriebsverantwortlichen Stelle ist es technisch möglich, sich an das NOOTS über einen einzelnen, gemeinsam genutzten SAK anzuschließen. Diese Funktionalität des SAK wird als Mandantenfähigkeit bezeichnet und die an denselben SAK angeschlossenen NOOTS-Teilnehmer heißen Mandanten. Um die grundlegende Unabhängigkeit der Daten der Mandanten hierbei zu bewahren, ist es notwendig eine Mandantentrennung, d.h. eine physische oder logische Trennung nach Mandanten bei der Speicherung und Verarbeitung von Daten, durchzusetzen.

In Bezug auf den Betrieb eines SAK betrifft die Mandantentrennung:

- die Konfiguration des SAK,
- den Datenaustausch zwischen DC bzw. DP und jeweiligem SAK im Rahmen eines Nachweisabrufs über die SAK Consumer- bzw. Provider-API,
- das Weiterverarbeiten von über die Logging-API des SAK bezogenen Logdaten und
- ggf. die Weiterverarbeitung von über die Tracing-API bezogenen Daten zur Nachverfolgbarkeit von Nachweisanfragen.

Da ein SAK sowohl in einer klassischen Serverstruktur als auch in einer Container-Umgebung betrieben werden kann, unterscheiden sich zum Teil die konkreten Maßnahmen, die die betriebsverantwortliche Stelle in Bezug auf die Umsetzung der Mandantentrennung beachten muss.

Die folgenden Anforderungen sind von Seiten der betriebsverantwortlichen Stelle, die einen SAK mit mehreren Mandanten betreibt, umzusetzen. Je nach Verwaltungsbereich muss darüber hinaus geprüft werden, welche weiteren Vorgaben bzgl. der Mandantentrennung durch andere rechtliche Rahmenbedingungen gemacht werden. Über den Betrieb des SAK hinausgehende Anforderungen an die Mandantentrennung innerhalb des Informationsverbunds einer betriebsverantwortlichen Stelle sind nicht Gegenstand dieser Richtlinie.

- [SAK.2.8] Jeder SAK MUSS auch bei Verwendung der Mandantenfähigkeit genau eine betriebsverantwortliche Stelle besitzen. Den angeschlossenen DCs KÖNNEN mehrere fachverantwortliche Stellen zugeordnet sein, die fachliche Verantwortung MUSS aber geklärt und dokumentiert sein.
- [SAK.2.9] Die Verarbeitung und Speicherung der die Mandanten eines SAK betreffenden Daten MUSS physisch oder logisch getrennt erfolgen.

- [SAK.2.10] Die gemeinsame Nutzung des SAK MUSS so implementiert sein, dass keine unbefugte Datenweitergabe zwischen den Mandanten möglich ist, da die Daten im SAK in unverschlüsselter Form vorliegen.
- [SAK.2.11] Die Anzahl der Mandanten, die sich einen SAK teilen, MUSS im Rahmen der Risikoanalyse gemäß BSI-Standard 200-3 (7) betrachtet und auf eine nach genauer Abwägung festgelegte Maximalzahl beschränkt werden. Hierbei MÜSSEN außer der zu erwartenden Last auch die Folgen betrachtet werden, die sich daraus ergeben können, wenn der betreffende SAK ausfällt und damit den Zugang aller seiner Mandanten zum NOOTS abschneidet. Es SOLLTE auch der möglicherweise unterschiedliche Schutzbedarf der Daten, die durch die verschiedenen Mandanten verantwortet werden, in die Erwägung einbezogen werden. Auch die Verwendung eines gemeinsamen SAK über verschiedene Verwaltungsbereiche hinweg SOLLTE abgewogen werden.

6.3 Vorgaben zur Verfügbarkeit

Das NOOTS besitzt eine dezentrale Struktur, bei der der eigentliche Nachweisaustausch zwischen den SAK der NOOTS-Teilnehmer stattfindet. Es beruht darauf, dass diese SAK zuverlässig zur Verfügung stehen.

Da die Kommunikation in verschlüsselter und mehrfach abgesicherter Form über das Internet als zugrunde liegendes physisches Netzwerk verläuft, besteht die Gefahr von DOS- oder DDOS-Angriffen nicht nur für die zentralen NOOTS-Komponenten, sondern auch für die einzelnen SAK.

Wiederholt oder dauerhaft nicht durchführbare Nachweisabrufe über das NOOTS könnten das Vertrauen der Bevölkerung in einen funktionierenden und leistungsfähigen Staat schwächen sowie wirtschaftlichen Schaden verursachen.

Folgende Anforderungen werden daher an die Verfügbarkeit der SAK gestellt:

- [SAK.3.1] Der SAK MUSS die Verfügbarkeitsanforderungen erfüllen, die durch das Bundesverwaltungsamt als betriebsverantwortliche Stelle des NOOTS vorgegeben werden.
- [SAK.3.2] Bei der Ermittlung der Maßnahmen für die Umsetzung von [SAK.3.1] MÜSSEN die potentielle Nutzerbasis sowie eventuelle Stichtage und Fristen imungsverfahren berücksichtigt werden, die zu Lastspitzen bzw. erhöhten Zugriffszahlen auf den Dienst führen können.
- [SAK.3.3] Die fach- und die betriebsverantwortliche Stelle MUSS für jeden SAK auf Basis der zu erwartenden Last in Nachweisabrufprozessen des NOOTS sowohl eine angemessene Bandbreite der Internetverbindung, über die er betrieben wird, als auch eine angemessene Rechenkapazität zur Verfügung stellen.
- [SAK.3.4] Die betriebsverantwortliche Stelle MUSS den SAK in ihr eigenes Monitoring einbeziehen bzw. für den SAK ein Monitoring einrichten, das mindestens die folgenden Ausgaben des SAK verarbeiten muss:
- Logging zur Fehleranalyse,
 - Nachrichtenverfolgung via TraceID (transparent),
 - Monitoring z.B. via HealthChecks / Monitoring-API des SAK.
- [SAK.3.5] Da die SAK vom Internet aus erreichbar sind, MÜSSEN Maßnahmen zur Abwehr von DOS- oder DDOS-Angriffen getroffen werden. Falls Rate-Limiting eingesetzt wird, so SOLLTE die Abschätzung nach[SAK.1.12] mit in die Wahl der Schwellenwerte einfließen.
- [SAK.3.6] Wenn ein SAK für mehrere Mandanten betrieben wird, SOLLTEN zusätzliche Maßnahmen zur Sicherstellung der Verfügbarkeit getroffen werden. Ein redundanter SAK Betrieb SOLLTE geprüft werden.

7 Anforderungen an Data Consumer (DC) und Data Provider (DP)

Da die SAK nicht als Selbstzweck betrieben werden, sondern der Durchführung eines Nachweisabrufprozesses über das NOOTS dienen und nur in Kombination mit einem DC oder DP nutzbar sind, ergeben sich aus dem Anschluss an das NOOTS mittels eines SAK auch Anforderungen an den oder die daran angeschlossenen DC bzw. DP. Zusätzlich zur Umsetzung der IT-Grundschutz-Anforderungen, die in Kapitel 5 aufgelistet sind, und ergänzend zu anderen Vorgaben, wie sie beispielsweise durch die TR-03172 für Onlinedienste im Rahmen des Portalverbundes (4) gelten, werden im Folgenden Informationssicherheitsanforderungen formuliert, die von allen DC und DP umzusetzen sind, sowie separate Anforderungen, die nur für die jeweilige Anschlussklasse gelten. Zu beachten ist, dass von der Intermediären Plattform, die fachlich vom Bundesverwaltungsamt verantwortet wird, sowohl die Anforderungen an DC als auch die an DP umzusetzen sind, da sie in beiden Rollen agiert.

7.1 Anforderungen, die für DC und DP gelten

Die Sicheren Anschlussknoten stellen die Endpunkte der Ende- zu-Ende-Verschlüsselung innerhalb des NOOTS dar, da in ihnen die Daten entschlüsselt werden, um eine Schemavalidierung und Virenprüfung vorzunehmen. Für den weiteren Transportweg zum DC bzw. DP müssen die Daten wieder verschlüsselt und mit einem Datenauthentifizierungsverfahren gesichert werden, um so den gesamten Übertragungsweg zwischen DC und DP abzusichern. Der SAK erzwingt daher eine TLS-Verschlüsselung bei der Übertragung von Daten an den ihn betreibenden DC oder DP.

Über die Absicherung des Transportkanals zwischen DC bzw. DP und entsprechendem SAK hinaus, ist die Umsetzung weiterer Anforderungen notwendig, um die Sicherheit der Kommunikation zwischen DC und DP zu gewährleisten. Die sicherheitstechnischen Anforderungen, die beide Anschlussklassen betreffen, sind im Folgenden aufgeführt:

- [DCDP.1] Die fach- und die betriebsverantwortlichen Stellen eines DC oder DP MÜSSEN sich und die von ihnen verantworteten bzw. betriebenen technischen Komponenten im Rahmen des Anschlusses an das NOOTS über die vom Bundesverwaltungsamt als betriebsverantwortliche Stelle des NOOTS vorgegebenen Wege registrieren.
- [DCDP.2] Die fachverantwortliche oder betriebsverantwortliche Stelle eines DC oder DP MUSS die für ihren DC bzw. DP im Datenmanagementsystem DAMAS des NOOTS hinterlegten Daten in DAMAS einpflegen und gemäß der Vorgaben von DAMAS regelmäßig aktualisieren. Bei längerer Unterbrechung bzw. Außerdienststellung eines DC oder DP MUSS die betriebsverantwortliche Stelle sicherstellen, dass die Registrierung der Komponente in DAMAS ausgesetzt wird, damit die entsprechenden Zertifikate zurückgezogen und für diese Komponente keine weiteren Zugriffstoken durch das IAM für Behörden ausgestellt werden.
- [DCDP.3] Jeder Data Consumer (DC) und Data Provider (DP) MUSS einen SAK für jede Interaktion mit dem Ziel einer Datenübertragung über das NOOTS verwenden. Zum Abruf von Nachweisen MUSS der für DC konzipierte SAK verwendet werden, zur Beantwortung von Nachweisabrufen MUSS der für DP konzipierte SAK eingesetzt werden.
- [DCDP.4] Tritt eine Stelle sowohl als DC als auch als DP auf, MUSS sie zwei SAK-Instanzen verwenden, die sie jeweils NUR für den intendierten Zweck einsetzen DARF. Stellt das BVA als betriebsverantwortliche Stelle des NOOTS mandantenfähige SAKs zur Verfügung, so DÜRFEN sie NUR entsprechend dem vom BVA vorgesehenen Einsatz verwendet werden.
- [DCDP.5] Anschlussprotokoll: Bei der Datenübertragung zwischen einem SAK und dem ihn betreibenden DC oder DP MUSS eine TLS-Verschlüsselung verwendet werden. Der DC oder DP MUSS

sich dazu entweder mittels HTTP Basic Authentication (14) oder mittels mTLS gegenüber dem von ihm betriebenen SAK authentifizieren.

- [DCDP.6] Es DÜRFEN dabei NUR Protokolle eingesetzt werden, die kryptografische Algorithmen verwenden, welche gemäß der TR-03116-4 (15) zulässig sind. TLS SOLLTE in der Version 1.3 verwendet werden.
- [DCDP.7] Die zur Kommunikation verwendeten Verschlüsselungsverfahren SOLLTEN postquantensicher sein. Im Falle von Schlüsselaustauschverfahren bedeutet das, dass eine Kombination aus klassischen und quantensicheren Verfahren verwendet werden SOLLTE. Im Falle von symmetrischer Verschlüsselung ist auf ausreichende Schlüssellänge gemäß der TR-02102-1 (12) zu achten.
- [DCDP.8] Es MUSS ein Konzept entwickelt werden, welches für den Fall der Weiterentwicklung der Verschlüsselungs- bzw. Datenauthentisierungsverfahren oder des Diebstahls von Schlüsseln oder Ähnlichem den Austausch der Verfahren und/oder des kryptografischen Materials ermöglicht und zwingend vorschreibt (Kryptoagilität).
- [DCDP.9] Falls im Rahmen von Übermittlung oder Empfang von Nachrichten eine Fehlfunktion des NOOTS oder eine Abweichung von den im NOOTS vorgesehenen Prozessschritten auffällt, MUSS der Nachweisabrufprozess abgebrochen werden. Bereits empfangene Daten DÜRFEN NICHT weiterverarbeitet werden. Über entsprechende Meldewege MUSS das NOOTS über den Vorfall informiert werden.
- [DCDP.10] Fehlerhafte Nachrichten SOLLTEN NICHT außerhalb der Fehleranalyse gespeichert werden. Sie SOLLTEN NICHT ohne zusätzliche Sicherungsmaßnahmen gegen möglicherweise enthaltenen Schadcode geloggt werden.
- [DCDP.11] Erhält ein System des DC bzw. DP von dem für ihn agierenden SAK eine Fehlermeldung, so DARF es darauf NICHT mit einer eigenen Fehlermeldung an den SAK antworten. Gegebenenfalls SOLLTE eine manuelle Klärung erfolgen.
- [DCDP.12] Können Nachrichten, die ein DC oder DP erstellt hat, nicht gesendet werden – beispielsweise wegen Nicht-Verfügbarkeit des entsprechenden SAK – so MÜSSEN sie nach einer festzulegenden Zeit automatisiert gelöscht werden. Dieser Vorgang SOLLTE protokolliert werden.

7.2 Spezifische Anforderungen an Data Provider (DP)

Data Provider stellen im NOOTS eine eigene Anschlussklasse dar. Da sie die Datenquellen sind, kommt ihnen die Verantwortung für die Richtigkeit, Aktualität und Sicherheit der übermittelten Nachweise zu.

Das NOOTS übernimmt bei der Datenübertragung klar abgegrenzte Prüfmechanismen. Unter anderem wird durch die Vermittlungsstelle eine abstrakte Berechtigungsprüfung der Datenübermittlung zwischen DC und DP durchgeführt. Hierbei greift die Vermittlungsstelle aber nicht auf die Inhaltsdaten der XNachweis-Nachricht zu. Daher obliegt es den Data Providern, zu überprüfen, ob das Token der Vermittlungsstelle den Inhalten der Nachweisanfrage entspricht.

Anhand mitgelieferter Token kann der DP ferner verifizieren, von welchem DC die Nachweisanfrage gesendet wurde. Auch die gesiegelten Authentifizierungsdaten des anfragenden Nutzers können durch den DP anhand der mitgelieferten Token nachgeprüft werden.

Inhaltliche Prüfungen der Rechtmäßigkeit einer Nachweisabrufanfrage wie beispielsweise das Beachten von Sperreinträgen in Registern sind dem NOOTS als Transportsystem ebenfalls nicht möglich und müssen zwingend durch den DP selbst durchgeführt werden. Letzten Endes trägt dieser die Verantwortung für die Herausgabe der Daten.

Folgende Anforderungen werden daher an Data Provider gestellt:

- [DP.1] Data Provider SOLLTEN sämtliche von ihrem SAK an sie weitergeleiteten Token selbstständig verifizieren, bevor sie einen Nachweisabruf beantworten.

- [DP.2] Schlägt die Prüfung der Teilnahmeberechtigung des anfragenden DC fehl, so DARF die Anfrage NICHT weiterverarbeitet werden. Dies MUSS protokolliert werden. Es SOLLTE eine Fehlermeldung gesendet werden. Dies gilt ebenfalls, wenn die Siegelung des entsprechenden Tokens nicht verifiziert werden kann oder seine zeitliche Gültigkeit abgelaufen ist.
- [DP.3] Schlägt die Prüfung der Authentifizierung der abfragenden Person auf dem für den Nachweisabruf erforderlichen Niveau fehl, DARF der angeforderte Nachweis NICHT geliefert werden. Dies MUSS protokolliert werden. Es SOLLTE eine Fehlermeldung gesendet werden. Dies gilt ebenfalls, wenn die Authentifizierung auf dem geforderten Niveau erfolgt ist, aber die Siegelung des entsprechenden Tokens nicht verifiziert werden kann, seine zeitliche Gültigkeit abgelaufen ist oder seine Nonce bereits bearbeitet wurde.
- [DP.4] Ruft eine natürliche Person Nachweise ab, deren Nachweissubjekt eine andere natürliche Person ist, MUSS die nachweisliefernde Stelle prüfen, ob sie dazu durch eine Vertreterregelung autorisiert ist. Schlägt die Prüfung der Autorisierung der abfragenden Person fehl, DARF die Anfrage NICHT weiterverarbeitet werden. Dies MUSS protokolliert werden. Es SOLLTE eine Fehlermeldung an den Kommunikationspartner gesendet werden. Dies gilt ebenfalls, wenn die Autorisierung attestiert wird, aber die Siegelung des entsprechenden Tokens nicht verifiziert werden kann, seine zeitliche Gültigkeit abgelaufen ist oder seine Nonce bereits bearbeitet wurde.
- [DP.5] Der DP MUSS überprüfen, dass die im Datenfeld „Nachweistyp“ des von der Vermittlungsstelle ausgestellten Abruftokens enthaltene Information zu der entschlüsselten Nachricht passt. Schlägt diese Überprüfung fehl, so DARF die Anfrage nicht weiterverarbeitet werden. Der Vorgang MUSS protokolliert werden. Es SOLLTE eine Fehlermeldung gesendet werden. Dies gilt ebenfalls, wenn die Siegelung des entsprechenden Tokens nicht verifiziert werden kann, seine zeitliche Gültigkeit abgelaufen ist oder seine Nonce bereits bearbeitet wurde.
- [DP.6] Der DP MUSS überprüfen, dass die im von der Registerdatennavigation ausgestellten Zuständigkeitstoken hinterlegten Daten über den Empfänger der ihm überstellten Anfrage seinen eigenen Daten entsprechen. Schlägt diese Überprüfung fehl, DARF die Anfrage NICHT weiterverarbeitet werden. Dies MUSS protokolliert werden. Es SOLLTE eine Fehlermeldung an den Kommunikationspartner gesendet werden. Dies gilt ebenfalls, wenn die Siegelung des Zuständigkeitstoken nicht verifiziert werden kann, seine zeitliche Gültigkeit abgelaufen ist oder seine Nonce bereits bearbeitet wurde.
- [DP.7] Antwortnachrichten, die der DP erstellt, MÜSSEN die gleiche Nachrichtenidentifikationsnummer enthalten wie die Anfrage, die sie beantworten. Siehe hierzu auch [DC.6]
- [DP.8] Der DP MUSS für die Antwortnachrichten den XNachweis-Standard umsetzen.
- [DP.9] Jeder Nachweisabruf unter Verwendung der IDNr. MUSS entsprechend der gesetzlichen Vorgaben im IDNrG (16) von der nachweisliefernden Stelle protokolliert werden. Das Protokoll MUSS von berechtigten, authentifizierten natürlichen Personen über das Datenschutzcockpit (DSC) einsehbar sein.
- [DP.10] Für Data Provider SOLLTEN aufgrund ihrer zentralen Rolle im NOOTS erhöhte Verfügbarkeitsanforderungen umgesetzt werden, um den kontinuierlichen Zugriff auf Registerdaten sicherzustellen. Dies umfasst Maßnahmen zur Redundanz (z.B. Mehrfachserver, mehrere Standorte), zum kontinuierlichen Monitoring und Erkennen von Ausfällen sowie zur Minimierung von Ausfallzeiten.
- [DP.11] Data Provider SOLLTEN auf Basis der zu erwartenden Last für Nachweisabrufprozesse des NOOTS eine angemessene Rechenkapazität zur Verfügung stellen.
- [DP.12] Falls im SAK des DP X509.-TLS-Server-Zertifikate für die Kommunikation mit den SAK der DC eingesetzt werden, die nicht der PKI des NOOTS entstammen, so MÜSSEN Zertifikate verwendet werden, die der V-PKI (17) entstammen, oder die von einer öffentlichen Certificate Authority bezogen werden, die zum einen mindestens den CA/B-Forum Basisanforderungen (18) in der aktuell gültigen Fassung genügt und zusätzlich Kryptoverfahren und Schlüssellängen verwendet, die der BSI TR-02102-2 (19) genügen.

7.3 Anforderungen an Data Consumer

Ein Data Consumer bindet sich über einen SAK an das NOOTS-Netz zum Nachweisdatenaustausch an. Dadurch nutzt der DC die Infrastruktur und die zentral zur Verfügung gestellten Dienste des NOOTS und kann prinzipiell über die SAK der Data Provider auf den Datenbestand aller angebundenen Register zugreifen. Somit sind Vorkehrungen und Maßnahmen erforderlich, die einen sicheren Betrieb der gesamten NOOTS-Infrastruktur einerseits und den ordnungsgemäßen Betrieb der Serviceleistung des DCs andererseits sicherstellen.

Damit die im NOOTS vorgesehenen Absicherungsmaßnahmen der Nachweisabrufe greifen können, müssen folgende Anforderungen an den DC gestellt werden:

- [DC.1] Jedem DC wird durch das IAM für Behörden eine Komponenten-ID zugeordnet, die für jede betriebsverantwortliche Stelle eindeutig ist und den verantwortlichen Stellen mitgeteilt wird. Diese Komponenten-ID des DCs MUSS beim Datenaustausch über das NOOTS mitgeliefert werden.
- [DC.2] Jede Anfrage für den Abruf des Zugriffstokens bei der zentralen NOOTS-Komponente IAM für Behörden MUSS den Vorgaben des Bundesverwaltungsamts entsprechend durch den DC gesiegelt werden.
- [DC.3] Der DC MUSS die Integrität der vom SAK übermittelten Daten prüfen. Schlägt die Prüfung fehl, DARF die Nachricht nicht weiterverarbeitet werden und MUSS verworfen werden. In diesem Fall MUSS eine Fehlermeldung zurückgeliefert werden und der Vorgang MUSS protokolliert werden.
- [DC.4] Der DC MUSS sicherstellen, dass der Nutzer, der den Nachweisabruf anstößt, mit dem notwendigen Vertrauensniveau authentifiziert wurde. Der Nachweis dieser Authentifizierung MUSS an die vorgesehenen Komponenten des NOOTS weitergereicht werden und MUSS den technischen und kryptographischen Vorgaben des NOOTS entsprechen.
- [DC.5] Der DC MUSS den Nachweisabrufstandard XNachweis umsetzen und nutzen.
- [DC.6] Der DC MUSS jede Anfrage zum Nachweisabruf an einen DP mit einem Zeitstempel und einer zufällig mit hinreichender Entropie gewählten, einmaligen Nachrichtenidentifikationsnummer und einer eindeutigen Trace-ID versehen, um Replayattacks zu verhindern.
- [DC.7] Die Rückantwort des Data Providers MUSS anhand der eindeutigen Nachrichtenidentifikationsnummer einer Anfrage eindeutig zugeordnet werden. Schlägt die Zuordnung einer empfangenen Nachricht fehl, DARF sie NICHT weiterverarbeitet werden. Eine Fehlermeldung MUSS zurückgeliefert werden. Der Vorgang MUSS protokolliert werden.
- [DC.8] Wenn eine empfangene Nachricht als Antwort auf eine Nachweisabfrage zugeordnet werden konnte, MUSS für die anfragende Person eine Vorschau des übertragenen Nachweises angeboten werden. Ohne die Zustimmung der anfragenden Person zu den in der Vorschau dargestellten Nachweisdaten DARF der Nachweis NICHT an andere Stellen weitergeleitet werden.
- [DC.9] Nach einer Zeitüberschreitung einer Anfrage ohne valide Rückmeldung MUSS die Anfrage abgebrochen werden und die vergebene Nachrichtenidentifikationsnummer als ungültig markiert werden. Es MUSS eine Fehlermeldung zurückgeliefert werden. Der Vorgang MUSS protokolliert werden.
- [DC.10] Der DC MUSS die Siegel in gesiegelten Nachrichten des Data Providers bzw. des SAK des Data Providers überprüfen. Schlägt die Prüfung fehl, DARF die Nachricht NICHT weiterverarbeitet werden. Eine Fehlermeldung MUSS zurückgeliefert werden. Der Vorgang MUSS protokolliert werden.
- [DC.11] DC MÜSSEN die Vorgaben der TR-03172-3 Onlinedienste (4) erfüllen, wenn sie die Funktionalitäten eines Onlinedienstes erfüllen.

Literaturverzeichnis

1. Regulation (EU) 2018/1724 of the European Parliament and of the Council establishing a single digital gateway to provide access to information, to procedures and to assistance and problem-solving services. [Online] 2. Oktober 2018. [Zitat vom: 10. Oktober 2025.] <http://data.europa.eu/eli/reg/2018/1724/oj>.
2. Bundesverwaltungsamt. AD-NOOTS. [Online] [Zitat vom: 12. 11 2025.] https://gitlab.opencode.de/noots/public/ad-noots/Architektur/-/tree/main/AD-NOOTS-XX?ref_type=heads.
3. Bundesamt für Sicherheit in der Informationstechnik. BSI TR-03176 IT-Sicherheitsanforderungen an die Datenübermittlung im NOOTS. [Online] 2025. <https://www.bsi.bund.de/dok/TR-03176>.
4. —. BSI TR-03172 Portalverbund. [Online] 14. November 2024. <https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Technische-Richtlinien/TR-nach-Thema-sortiert/tr03172/tr-03172.html>.
5. —. BSI-Standard 200-1: Managementsysteme für Informationssicherheit (ISMS). [Online] 15. November 2017. https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschatz/BSI_Standards/standard_200_1.html?nn=128578.
6. —. BSI-Standard 200-2: IT-Grundschatz-Methodik. [Online] 15. November 2017. <https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschatz/BSI-Standards/BSI-Standard-200-2-IT-Grundschatz-Methodik/bsi-standard-200-2-it-grundschatz-methodik.html>.
7. —. BSI-Standard 200-3: Risikomanagement. [Online] 15. 11 2017. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschatz/BSI-Standards/BSI-Standard-200-3-Risikomanagement/bsi-standard-200-3-risikomanagement_node.html.
8. International Organization for Standardization (Hrsg.). *ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection - Information security management systems - Requirements*. 2022.
9. Bundesamt für Sicherheit in der Informationstechnik. BSI-Standard 200-4: Business Continuity Management. [Online] 2023. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschatz/BSI-Standards/BSI-Standard-200-4-Business-Continuity-Management/bsi-standard-200-4_Business_Continuity_Management_node.html.
10. International Organization for Standardization (Hrsg.). *ISO 22301:2019, Security and resilience - Business continuity management systems - Requirements*. 2019.
11. Bundesamt für Sicherheit in der Informationstechnik (Hrsg.). *IT-Grundschatz-Kompendium*. Edition 2023. Köln : Reguvis, 2023. ISBN 978-3-8462-0906-6.
12. Bundesamt für Sicherheit in der Informationstechnik. BSI TR-02102-1 - Kryptographische Verfahren: Empfehlungen und Schlüssellängen. [Online] 31. Januar 2025. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Technische-Richtlinien/TR-nach-Thema-sortiert/tr02102/tr02102_node.html.
13. —. Key Lifecycle Security Requirements - Version 1.0.3. [Online] 17. November 2021. https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/ElekAusweise/CVCA/KeyLifecycleSecurityRequirements.pdf?__blob=publicationFile&v=3.
14. Reschke, Julian. IETF RFC 7617 - The 'Basic' HTTP Authentication Scheme. [Online] September 2015. <https://datatracker.ietf.org/doc/html/rfc7617>.

15. Bundesamt für Sicherheit in der Informationstechnik. BSI TR-03116 - Kryptographische Vorgaben für Projekte der Bundesregierung: Teil 4 - Kommunikationsverfahren in Anwendungen. [Online] 07. März 2023. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Technische-Richtlinien/TR-nach-Thema-sortiert/tr03116/TR-03116_node.html.
16. Gesetz zur Einführung und Verwendung einer Identifikationsnummer in der öffentlichen Verwaltung (Identifikationsnummerngesetz - IDNrG). [Online] 28. März 2021. <https://www.gesetze-im-internet.de/idnrg/BJNR059110021.html>.
17. Bundesamt für Sicherheit in der Informationstechnik. Public Key Infrastruktur der Verwaltung. [Online] https://www.bsi.bund.de/DE/Themen/Oeffentliche-Verwaltung/Moderner-Staat/Verwaltungs-PKI/verwaltungs-pki_node.html.
18. CA/Browser Forum. Baseline Requirements for the Issuance and Management of Publicly-Trusted TLS Server Certificates. [Online] <https://cabforum.org/working-groups/server/baseline-requirements/documents/>.
19. Bundesamt für Sicherheit in der Informationstechnik. BSI TR-02102-2 - Kryptographische Verfahren: Verwendung von Transport Layer Security (TLS). [Online] 21. Januar 2025. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Technische-Richtlinien/TR-nach-Thema-sortiert/tr02102/tr02102_node.html.
20. Bundesverwaltungsamt. AD-NOOTS-19: Grobkonzept Transportinfrastruktur. [Online] [Zitat vom: 11. 11 2025.] https://gitlab.opencode.de/noots/public/ad-noots/Architektur/-/blob/main/AD-NOOTS-XX/AD-NOOTS-19_+Grobkonzept+Transportinfrastruktur.md?ref_type=heads.

Abkürzungsverzeichnis

Abkürzung	Erklärung
beWiNr	Bundeseinheitliche Wirtschaftsnummer für Unternehmen
BSI	Bundesamt für Sicherheit in der Informationstechnik
BVA	Bundesverwaltungsamt als betriebsverantwortliche Stelle des NOOTS
DAMAS	Datenmanagementsystem
DC	Data Consumer
DP	Data Provider
EU-OOTS	Once-Only-Technical-System der Europäischen Union
HTTPS	HyperText Transfer Protocol - Secure
IAM	Identity and Access Management
IDA	Identitätsdatenabruf
IDM	Identitätsmanagementsystem
IDNr.	Identifikationsnummer im Sinne des Identifikationsnummerngesetzes
IDNrG	Identifikationsnummerngesetz
IP	Intermediäre Plattform
NOOTS	Nationales Once-Only-Technical-System
OZG	Onlinezugangsgesetz
PKI	Public Key Infrastruktur
RDN	Registerdatennavigation
SAK	Sicherer Anschlussknoten
TLS	Transport Layer Security
TR	Technische Richtlinie
UBRegG	Unternehmensbasisdatenregistergesetz
V-PKI	Verwaltungs-PKI
VS	Vermittlungsstelle